

Regulatory Compliance Gap Analysis

GLBA Safeguards Rule, PCI DSS v4.0, and FFIEC Cybersecurity Alignment

SecurityGroup101 | Enterprise GRC Program

Prepared By: Maxine Jones, GRC Analyst | Reviewed By: Compliance Lead

Version 1.0 | Classification: Confidential – Internal Use

1. Purpose and Scope

SecurityGroup101 provides financial services and processes payment card data, placing it in scope for the Gramm-Leach-Bliley Act (GLBA) Safeguards Rule, PCI DSS v4.0, and the FFIEC Cybersecurity Assessment Tool (CAT) expectations that govern partnerships with regulated financial institutions. This report consolidates the three regulatory gap analyses into a single view of current posture, identified deficiencies, and remediation priorities, each mapped to NIST CSF, ISO 27001, and COBIT 2019.

2. GLBA Safeguards Rule Gap Analysis

Evaluated across five control domains: governance and risk management, access controls, data protection and encryption, vendor risk management, and security monitoring and incident response.

Domain	Findings / Gaps	Recommendation
Governance & Risk Mgmt	No recurring enterprise risk program; security responsibilities not clearly defined at board level.	Implement annual NIST SP 800-30-aligned risk assessment; establish board-level oversight.
Access Controls	Inconsistent MFA enforcement; no formal joiner/mover/leaver (JML) process; privileged access not regularly reviewed.	Enforce MFA for all administrative/remote access; implement RBAC with quarterly access reviews.
Data Protection & Encryption	Inconsistent encryption at rest and in transit; no data loss prevention (DLP) controls.	Standardize encryption requirements; implement DLP across email, endpoints, and cloud.
Vendor Risk Management	No formal third-party risk management (TPRM) program; security requirements inconsistently defined in contracts.	Implement TPRM program with risk tiering and due diligence — addressed by the new Third-Party Risk Assessment Program.
Security Monitoring & IR	SIEM coverage limited to a subset of systems; no formal IR testing program.	Expand SIEM coverage; develop and test an incident response plan on a recurring basis.

3. PCI DSS v4.0 Crosswalk

Maps PCI DSS requirements applicable to the cardholder data environment (CDE), payment processing applications, and supporting infrastructure to NIST CSF, ISO 27001, and COBIT 2019.

Req.	Description	Mapped Control	State	Gap
1.2	Network Segmentation	NIST PR.AC-5, COBIT DSS01	Partial	Segmentation not formally validated
3.4	PAN Protection	ISO 27001 A.10, NIST PR.DS-1	Partial	Encryption not standardized
6.2	Vulnerability Management	NIST PR.IP-12, COBIT DSS05	Partial	No defined remediation SLAs
8.3	Strong Authentication	NIST PR.AC-7, ISO 27001 A.9	Partial	MFA not consistently enforced
10.2	Logging and Monitoring	NIST DE.CM-1, COBIT DSS05.04	Partial	Incomplete log sources and retention

Key gaps: absence of documented quarterly ASV scans, lack of formal network segmentation validation, log retention below the 12-month PCI DSS requirement, and inconsistent MFA enforcement for administrative and remote access.

4. FFIEC Cybersecurity Alignment

Domain	Required Capability	Current State	Gap Level	Recommendation
Governance	Board/executive oversight	Partial	Medium	Establish formal GRC reporting and risk appetite
Risk Management	Enterprise risk program	Partial	High	Conduct annual NIST SP 800-30-aligned assessments
Security Controls	Access, data, system security	Partial	High	Implement RBAC, enforce MFA, standardize encryption
Threat Intelligence	Threat monitoring/integration	Minimal	Medium	Integrate threat feeds into SIEM detection use cases
Security Monitoring	Logging, alerting, anomaly detection	Partial	Medium	Expand SIEM coverage and correlation capability
Resilience	BC/DR capability	Partial	High	Align DRP/BCP to NIST SP 800-34; test regularly

5. Cross-Framework Key Insights

All three regulatory lenses converge on the same underlying weaknesses: governance and risk management gaps create systemic exposure across every other control domain; identity and access management deficiencies (inconsistent MFA, no JML process, infrequent privileged-access review) increase the likelihood of unauthorized access; monitoring and detection capabilities are not yet sufficient to reliably identify active threats; and vendor risk has been a blind spot until the recent introduction of a formal third-party risk program. These findings are the basis for the Implementation status assigned throughout the Statement of Applicability and the prioritization of the GRC Roadmap.

6. Remediation Priorities

Priority	Action	Driving Requirement(s)
1	Enforce MFA across all administrative and remote access	GLBA, PCI DSS 8.3, FFIEC Security Controls
2	Formalize vendor / third-party risk management program	GLBA Vendor Risk Mgmt
3	Validate and document CDE network segmentation	PCI DSS 1.2
4	Standardize encryption at rest across systems handling cardholder/customer data	GLBA, PCI DSS 3.4
5	Expand SIEM coverage and log retention to 12+ months	PCI DSS 10.2, FFIEC Security Monitoring
6	Establish and test a formal incident response plan	GLBA, FFIEC Resilience

These gap analyses are integrated into the unified control catalog, the quantitative risk register, and the 18-month GRC roadmap to ensure consistent governance and a single source of truth for remediation tracking.